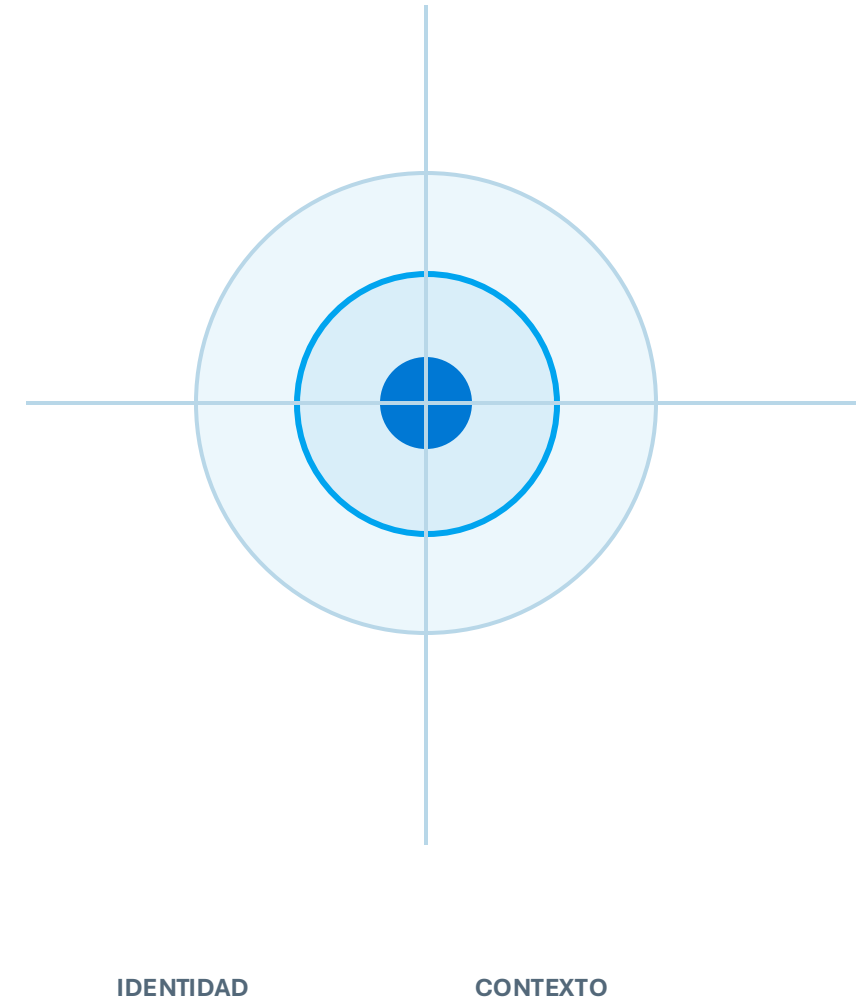


Seguridad de acceso de usuarios

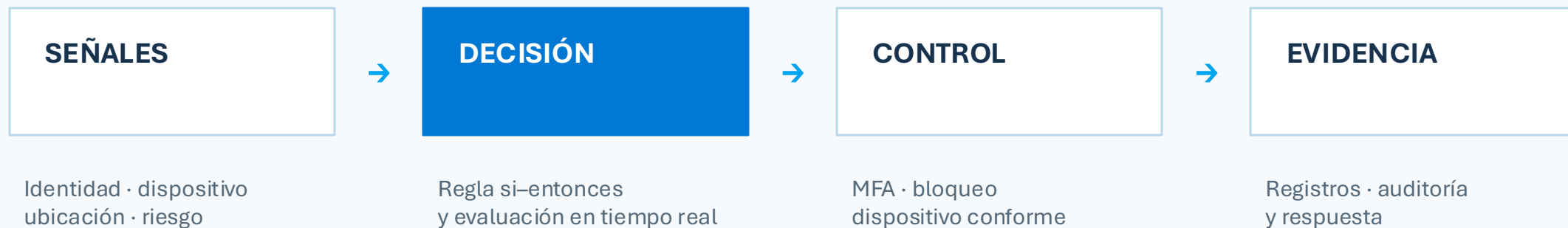
Identidad, autenticación fuerte, acceso condicional y diagnóstico

Microsoft Entra ID



La seguridad de acceso es una cadena de decisiones

Una credencial válida no basta: el acceso seguro combina contexto, control y evidencia.



Objetivo operativo

Permitir el trabajo legítimo y elevar la fricción solo cuando el riesgo lo exige.

Cinco herramientas, una misma capa de identidad

Microsoft Entra ID actúa como núcleo; los portales, protocolos y APIs amplían su alcance.

Centro M365

Usuarios · grupos · licencias

Graph PowerShell

Automatización y RBAC

ENTRA ID

SSO

SAML · OAuth · OIDC · WS-Fed

Microsoft Graph API

Datos y relaciones M365

Una identidad · múltiples dispositivos y aplicaciones

SSO puede abarcar nube y on-premises mediante Application Proxy, Connect Sync o AD FS.

Las contraseñas se protegen mejor sin rotaciones rutinarias

RECOMENDADO

No expirar por defecto

- MFA como control principal
- Password Protection y Smart Lockout
- SSPR para reducir dependencia de soporte

EXCEPCIÓN CONTROLADA

Configurar expiración

14–730

días configurables

La rotación periódica puede inducir contraseñas débiles o predecibles.

Principio: cambiar la contraseña ante riesgo o compromiso, no por rutina.

Los roles delimitan quién puede restablecer y proteger credenciales

Separar funciones reduce privilegios permanentes y facilita la auditoría.

Rol	Restablecer contraseñas	Protección y políticas
Global Administrator	Sí · todas las tareas	Sí
Security Administrator	Según ámbito	Sí
Privileged Role Administrator	Según ámbito	Sí
User Administrator	Sí	No
Password Administrator	Sí	No

Aplicar mínimo privilegio y reservar las cuentas Global Administrator para escenarios excepcionales.

Password Protection corta contraseñas previsibles antes del ataque

La validación combina inteligencia global de Microsoft con términos propios de la organización.

GLOBAL

Siempre

activa en el tenant

- Basada en telemetría de Entra ID
- Se actualiza continuamente
- No se publica ni puede deshabilitarse

PERSONALIZADA

1.000

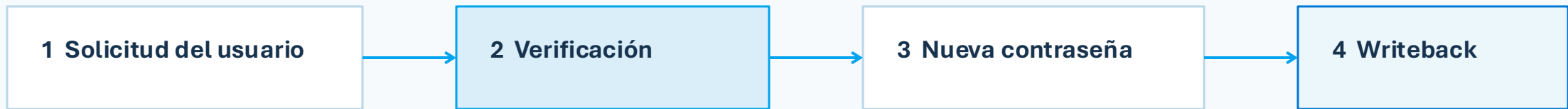
términos máximos

- Marcas, productos, ubicaciones y términos internos
- Detecta mayúsculas y sustituciones comunes
- Longitud de términos: 4–16 caracteres

Mitiga password spray: pocas contraseñas débiles contra muchas cuentas.

SSPR reduce soporte sin perder control híbrido

El autoservicio debe habilitarse explícitamente para todos o para grupos seleccionados.



Correo alternativo • llamada • SMS • preguntas de seguridad

Administradores: dos métodos y sin preguntas de seguridad.

Escenario híbrido

Entra Connect Sync + password writeback

Requiere licencias Entra ID Premium para devolver el cambio a AD DS local.

Sin writeback, SSPR se limita a identidades en la nube no vinculadas a AD DS.

Smart Lockout frena fuerza bruta sin penalizar tanto al usuario

10

intentos fallidos

60

segundos iniciales

3

contraseñas fallidas
recordadas

El bloqueo aumenta desde el intento 11; repetir la misma contraseña incorrecta no vuelve a incrementar el contador.

Con PTA

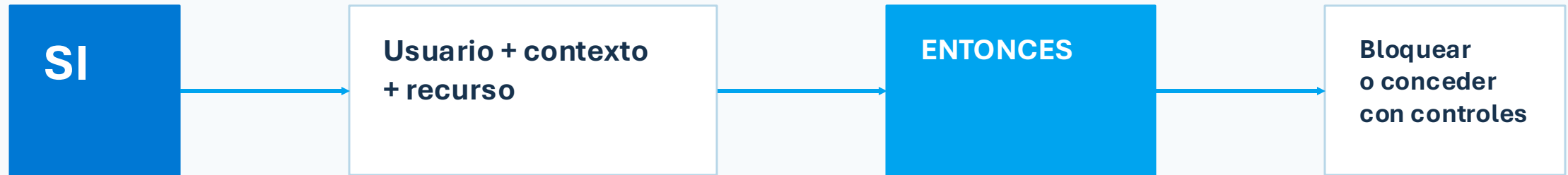
- Umbral de Entra menor que el umbral de AD
- Duración de Entra mayor que el contador de reinicio de AD
- No está disponible el rastreo por hash

**Siempre
activo**

Personalizar valores
requiere licencia paga

Acceso condicional convierte señales en decisiones

Se evalúa después del primer factor y aplica reglas “si-entonces” al recurso solicitado.



Ejemplo

Si el usuario accede a nómina, exigir MFA y dispositivo conforme.

No reemplaza defensas contra ataques DoS.

Una política se diseña de izquierda a derecha



Ubicaciones con nombre
Hasta 195 ubicaciones · 2.000 rangos IP por ubicación · rangos CIDR mayores a /8

Las señales combinan identidad, red, dispositivo, app y riesgo

IDENTIDAD

Usuario · grupo · rol

DISPOSITIVO

Plataforma · conformidad · unión

**DECISIÓN
DE ACCESO**

RED

IP · país · ubicación confiable

APLICACIÓN

Recurso · cliente · contexto

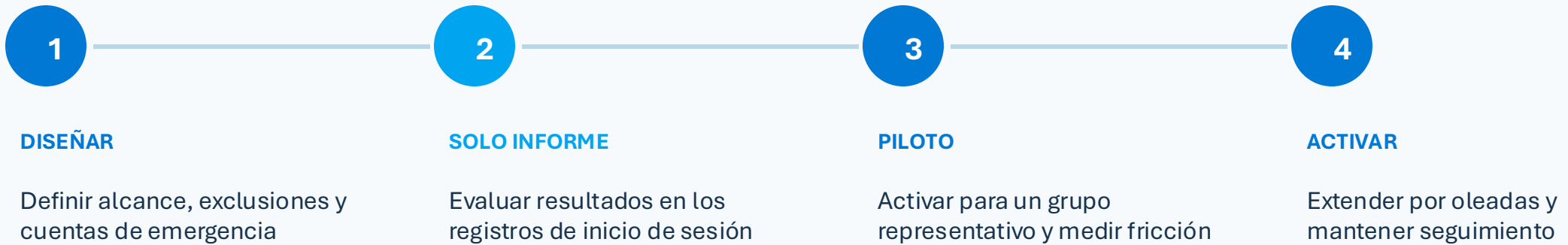
RIESGO

Entra ID Protection · tiempo real

Defender for Endpoint e Intune aportan estado de cumplimiento para bloquear equipos o apps no administrados.

Report-only permite desplegar controles sin interrumpir el negocio

Primero observar; después endurecer. La telemetría evita bloqueos inesperados.



Patrón seguro

No activar una política amplia sin revisar primero su impacto en report-only.

MFA debe aplicarse con el mecanismo correcto

Acceso condicional	Recomendado	Granular por grupo, app, dispositivo y riesgo	P1/P2 o suites compatibles
Security Defaults	Inicio rápido	Todo o nada; MFA y bloqueo de legado	Entra Free
MFA por usuario	Legado	Gestión individual, menor contexto y escalabilidad	No recomendado a escala
Métodos	Authenticator · SMS/llamada · OATH · TOTP · claves FIDO2		

Authentication strength eleva MFA a resistencia frente a phishing

La política especifica qué combinaciones registradas son válidas para cada recurso.

Método permitido



Método registrado



Política del recurso

MFA

Dos o más factores

MFA sin contraseña

Biometría o claves FIDO2

MFA resistente a phishing

FIDO2 y Windows Hello

Sin método compatible: registro combinado o bloqueo.

Passwordless desplaza el secreto compartido

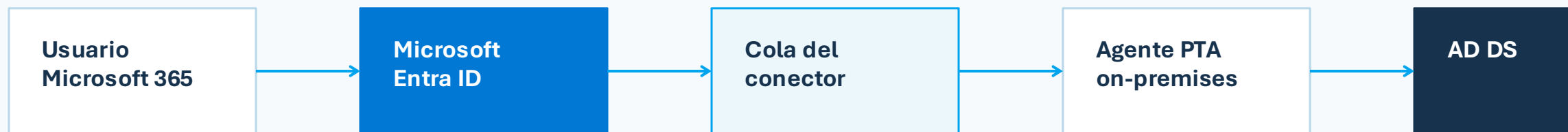
La autenticación se vincula al dispositivo, al hardware o a una clave criptográfica resistente al phishing.

01	Windows Hello for Business	PIN o biometría local + TPM · SSO
02	Microsoft Authenticator	Push con coincidencia de número y biometría/PIN
03	Passkeys FIDO2	USB, Bluetooth o NFC · WebAuthn · escenarios sin teléfono
04	Platform Credential macOS	SSOe + enclave seguro + Touch ID
05	Platform SSO + SmartCard	Certificado y token físico administrado por MDM
06	CBA	Certificados X.509 directos contra Entra ID

Resultado **Menos secretos reutilizables, menos replay y menor superficie de phishing.**

PTA valida en AD local sin publicar infraestructura entrante

El agente usa comunicación saliente y valida la contraseña en tiempo real contra AD DS.



ALTA DISPONIBILIDAD

Desplegar un agente adicional en otro servidor.

RESILIENCIA

Mantener PHS habilitado como opción de conmutación.

Más simple que AD FS · agente unido al dominio · sin red perimetral entrante

Security Defaults y Conditional Access no se combinan

Criterio	Security Defaults	Conditional Access
Licencia típica	Entra Free	Entra P1/P2 o suite
Alcance	Todo el tenant	Granular y contextual
Métodos	Decididos por el servicio	Authentication strengths y controles
Exclusiones	No	Sí
Uso recomendado	Inicio rápido / TI limitada	Entornos con requisitos diferenciados

Transición **Deshabilitar Security Defaults antes de activar políticas de acceso condicional.**

Los registros separan cuatro patrones de inicio de sesión

1	INTERACTIVO	El usuario aporta un factor	Contraseña · MFA · biometría · QR · federación
2	NO INTERACTIVO	La app renueva tokens en segundo plano	Refresh token · SSO · FOCI
3	SERVICE PRINCIPAL	La aplicación usa su propia credencial	Certificado o client secret
4	MANAGED IDENTITY	Azure gestiona la credencial del recurso	VM u otro recurso solicita un token

Las entradas son generadas por el sistema y no se pueden modificar ni eliminar.

Investigar fallos exige seguir identidad, cliente, recurso y decisión

1 QUIÉN

Identidad, rol, tenant y tipo de inicio

2 CÓMO

Aplicación, cliente, protocolo y método

3 QUÉ

Recurso solicitado y permisos

4 POR QUÉ

Estado, riesgo y resultado de acceso condicional

Tres registros complementarios

Inicio de sesión

Accesos y uso de recursos

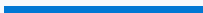
Auditoría

Cambios en el tenant

Aprovisionamiento

Altas y sincronización de objetos

La implementación segura avanza por capas

01		BASE	Password Protection · Smart Lockout · cuentas de emergencia
02		RECUPERAR	SSPR y writeback híbrido
03		FORTALECER	MFA con acceso condicional y strengths
04		ELIMINAR	Passwordless y bloqueo de autenticación heredada
05		OPERAR	Registros, report-only y mejora continua

Principio final: acceso mínimo, autenticación fuerte y evidencia siempre disponible.